

Security & trust

How Onam connects, what it stores, what it never stores, and how tenants stay isolated — the trust case for a read-only platform.

Least privilege

No stored secrets

Metadata not data

Per-tenant isolation

SOC 2 · ISO · PCI

EXECUTIVE SUMMARY

A security tool has to earn more trust than it asks for.

Onam reads your entire cloud. That access is exactly why our own security posture has to be exemplary and legible. This paper documents how Onam connects, what it stores, what it deliberately never stores, and how tenants are isolated — so a security team can grant access with confidence rather than hope.

The design principle is minimality: take the least privilege that permits a security read, hold no long-lived secrets, and retain only the metadata needed to describe a risk — never the data itself. Where a control is a stated certification, it is named; where something is planned rather than achieved, this paper does not claim it.

The short version. Read-only, agentless, short-lived tokens, per-tenant isolation with per-tenant keys, and a retention policy that keeps labels and locations but not contents. The rest of this paper is the detail behind each of those words.

01 Least-privilege connection

Every cloud is connected with the lowest standing privilege that still allows a security read, and no long-lived cloud credential is ever stored — only a reference (a role ARN or principal ID) held in a secrets manager and encrypted with a managed key. At scan time that reference is exchanged for a short-lived token.

Cloud	Mechanism	Privilege
AWS	Cross-account role, unique External ID/tenant	SecurityAudit + ReadOnlyAccess; STS ≤ 60 min
Azure	Entra service principal	Reader + read-only Graph
GCP	Service account or keyless WIF	6 read-only roles
OCI	IAM user + signing key	inspect + read only
Alibaba / IBM	RAM read-only · Service ID	Read-only; key → short-lived Bearer
Kubernetes	Read-only ServiceAccount	get / list / watch

Confused-deputy defense. The AWS connection requires a unique External ID per tenant, so one tenant's role can never be assumed on behalf of another. Tokens expire in an hour or less, and secret material is never written to logs.

02 What Onam never stores

The most important trust control is what does *not* enter the system. Onam keeps the metadata required to describe and price a risk and deliberately discards everything else.

FIGURE 1 — RETAINED VS NEVER RETAINED

RETAINED (metadata only)

- ✓ Asset inventory & relationships
- ✓ Finding metadata (rule, resource ref)
- ✓ Data labels & locations (DSPM)
- ✓ Credential references (not secrets)
- ✓ Config state needed to evaluate rules

NEVER RETAINED

- ✗ Object / file contents
- ✗ Database rows
- ✗ Workload disk / memory (ephemeral)
- ✗ Source code (finding metadata only)
- ✗ Personal data (labels + locations only)

DSPM classifies where sensitive data lives without keeping the data. Workload scanning uses ephemeral snapshots. SecOps retains finding metadata, not source.

03 Three layers of tenant isolation

- 1 Gateway.** An authenticated context is established at the BFF for every request before anything is read.
- 2 Engine.** A feature:action permission is checked at the engine boundary — 27 permissions across 5 seeded roles.
- 3 Database.** A tenant_id filter is applied on every query. Per-tenant encryption keys protect data at rest.

404, not 403. A cross-tenant probe returns "not found," never "forbidden" — so the system does not even confirm the existence of another tenant's resources.

04 Access control & identity

Onam ships role-based access control with five seeded roles mapped to 27 fine-grained feature:action permissions, so operators can grant exactly what a person needs. For enterprise identity, Onam supports **SAML SSO** and **SCIM** provisioning, so account lifecycle follows the customer's identity provider rather than a separate list to maintain.

05 Certifications & attestations

The following are stated as achieved. Onam maps a single finding to many controls, and supports 70+ compliance frameworks out of the box (covered in Whitepaper 05).

Attestation	Scope
SOC 2 Type II	Security, availability, confidentiality controls over a period
ISO 27001:2022	Information security management system
ISO 27017	Cloud-specific security controls
PCI DSS v4.0	Payment-card data security
CSA STAR Level 1	Cloud security self-assessment registry
GDPR	EU data-protection alignment
HIPAA BAA	Business Associate Agreement available

Stated, not aspirational. This paper lists only attestations Onam presents as achieved. Where a control is on a roadmap rather than in place, it is intentionally absent here — trust documentation that overstates is worse than none.

06 An honest boundary

Read-only means read-only. Onam's trust model is built on the fact that it does not sit in your data path. It does not enforce or block at runtime, and it does not hold your data. That is a deliberate limit, not an omission: the smaller the footprint and the less it retains, the smaller the blast radius if Onam itself were ever compromised. For live inline enforcement, Onam is complementary to a runtime tool — and its own posture is easier to trust precisely because it asks for so little.

07 Data handling at a glance

Dimension	Control
Cloud credentials	References only, KMS-encrypted; tokens $\leq$ 1 hr; never logged
Data contents	Never retained — labels & locations only
Workload access	Agentless; ephemeral snapshots, not persistent disk copies
Source code	Finding metadata retained; code not stored
Tenant isolation	Gateway → engine permission → DB <code>tenant_id</code> ; per-tenant keys
Identity	RBAC (5 roles / 27 perms) · SAML SSO · SCIM

08 Summary

Onam takes the least privilege that permits a security read, stores no long-lived cloud secrets, and retains metadata rather than data — labels and locations, not contents. Three isolation layers and per-tenant encryption keep tenants apart, with cross-tenant probes returning 404. The platform is backed by SOC 2 Type II, ISO 27001:2022 and 27017, PCI DSS v4.0, CSA STAR L1, GDPR alignment, and a HIPAA BAA. The trust case rests on a simple idea: a tool that reads everything should ask for as little as possible and keep even less.

Due-diligence ready. This paper doubles as the basis for a security questionnaire response. A read-only trial lets your team verify the connection privileges and retention behavior directly.